

Segula

IT SECURITY POLICY

Version 1.4**Validation**

VERSION	NAME	ROLE	DATE	SIGNATURE
1.0	Jose Moragues	Group Information Systems Director	12/2019	[APPROVED]
1.1	Mathieu Fremont	Technical Director	11/2020	[APPROVED]
1.2	Mathieu Fremont	Technical Director	05/2022	[APPROVED]
1.3	Mathieu Fremont	Technical Director	06/2023	[APPROVED]
1.4	Jose Moragues	Group Information Systems Director	03/2024	[APPROVED]

Latest revision: 23/03/2024A handwritten signature in purple ink, appearing to read "Jose Moragues".

Jose Moragues
Group Information Systems Director

History

Initials	Date	Revision	Comments
S.KE	12/2019	1.0	Document creation
S.KE	11/2020	1.1	Update
T.LE	05/2022	1.2	Format and update
T.LE	06/2023	1.3	Update
T.LE	06/2023	1.4	Technical updates

Table of contents

1	Purpose and field of application	4
2	Responsibility and authority	5
2.1	General responsibility	5
2.2	Update and maintenance of the IT Security policy	5
3	Principles	5
3.1	User Regulations	5
3.2	Back-up / Data Storage	6
3.3	Cloud Services	7
3.4	Contingency planning	7
3.5	General security concerns	7
3.6	Integration of security in projects	9
3.7	Network access	10
3.8	Supplier management	10
3.9	Antivirus	10
3.10	External storage	11
3.11	E-mails	11
3.12	Internet	11
3.13	Software and Hardware	11
3.14	Mobile Devices	12
4	CISO organizational structure	12
4.1	Description	12
5	References	13

1 Purpose and field of application

This document describes the IT Security Policy (PSSI), describes the organization, principles and main purpose of the IT security of Segula. It aims to present a general overview of IT security and is completed, for each chapter of ISO 27002 of another document detailing each panel of IT-Security. The complete list of all IT policies matches the model described in ISO 27001 and 27002.

The IT policies are completed with processes, tools and operations that complete and describe actions in regard with the IT Security Policy.

This document is applicable to all entities belonging to Segula Corporate, Segula Holding and managed by Segula IT.

In general terms, the Security Policy is applicable to all Segula employee, Segula subcontractors and when accessing or using Segula resources it can be applicable as well to Segula Partners and clients.

In particular the entities and teams that are most interested in the IT Security Policy would be:

- The CISO Group and corporate Security
- Segula IT in general and in particular:
 - o The System team
 - o The Network team
 - o The Developpement and Integration teams
 - o The IT Managers for each site
- The legal team

The IT Security Policy is organized the following way :

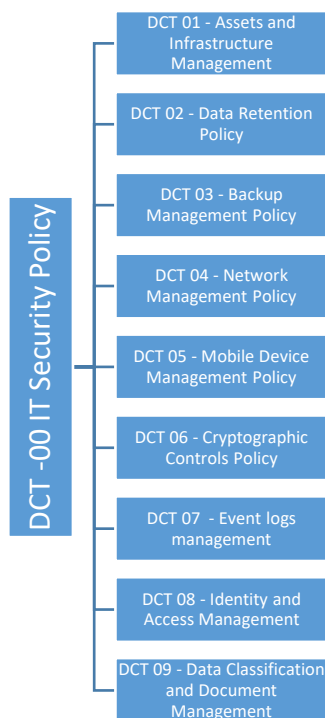


Figure 1 – IT Security Policy Structure

2 Responsibility and authority

2.1 General responsibility

The responsibility for compliance with these rules rests with the President.

The IT responsible in each entity of the DSI group is responsible for the implementation of these guidelines.

For scopes of authority, responsibilities and competences in general refer to chapter 4.

2.2 Update and maintenance of the IT Security policy

The IT Security policy is reviewed and if necessary updated at a frequency of once a year at the minimum. If the system landscape or the requirement need to change earlier, updates can be made when necessary.

When a significant update is done, it has to be reviewed first by the CISO and then by either the Technical Director or the CIO depending on the change scope.

3 Principles

The DSI considers its IT systems and all resulting use of them as the property of the company. IT systems include, in addition to hardware and software, documents, data files, databases, internet access, emails etc.

A proper functioning of the IT system is a prerequisite for proper supporting of processes in the company. All though many measures are taken to secure maximum availability of the services the system provides; it still relies on the employees to follow the below instructions. Any violation of these rules is considered as a major breach of confidence.

3.1 User Regulations

In general terms, Users have to follow the regulations contained in its contract and the different documentations they signed at onboarding. In particular concerning security, users have to follow:

- This IT Security Policy
- The IT end-user Charter
- A security sensitivity training at onboarding

Users will also be briefed by their managers and colleagues on Data Classification, and which data to consider as confidential or otherwise sensitive.

A set of general rules also have to be applied by the end user:

Users shall:

- Not use any IT systems or IT components without express permission.
- Not try to access information, if not sure that they are authorized to do so.
- Never change information on IT systems if not sure that they are authorized to do so.
- Not use IT systems for personal purposes.
- Not leave unsecured IT systems unobserved.

-
- Not use passwords of other people.
 - Remember that they are responsible for everything that happens under their Username and password.

3.2 Back-up / Data Storage

The backup data policy has to be followed in priority and shall contain the up to date processes and rules to be followed concerning the backup and storage.

In general terms, the backup of data is done on the central storage drives (servers). Each business relevant data needs to be stored on the central server NAS provided by the DSI to be able to be restored in case of malfunction or data loss.

The usage of external storage (USB Sticks / external hard disk / etc...) shall be avoided for data backup whenever possible.

When not using an HQ service, the business unit will have to implement a backup strategy coherent with the criticality of the data.

When implementing offside backups, the backup Medias shall be stored securely, preferably physically separated from the location of the data source in a fireproof environment.

3.3 Cloud Services

The use of cloud services (e.g. Dropbox; Box, etc.) is not allowed.

The DSI is the only responsible for Segula to implement and contract Cloud Services. In that regard, HQ IT will ensure that the security requirements of each Cloud solution follows the requirements of Segula and that it is coherent with the criticality of the data managed in the Cloud.

If a request from external partners / customers is placed this will be examined and decided from the IT department on a case by case evaluation.

3.4 Contingency planning

Each Business Unit will have to implement a business continuity Plan in case of incident. HQ IT maintains a Disaster Recovery Plan that is tested every Year.

Applications and services eligible to the plan have to define their RPO and RTOs and be available to test the DRP when an operation is done by HQ IT.

3.5 General security concerns

Security is everyone's concern, as a result it is understood in the company that:

- Users are aware of the security best practices either through informal or formal training
- IT personnel is in particular aware of the risks associated with higher access level and administrator responsibilities when applicable
- All users are sufficiently vetted at hiring

In general it is also understood that whenever possible users should keep security in mind and not act in a way that would put assets, information or systems at risks.

3.5.1 Passwords

Login to the internal networks or other system resources is controlled by user accounts and passwords. Passwords are confidential and shall therefore never be:

- Written, e-mailed, or spoken.
- Shared with other people.
- Hinted at or made easy to guess.
- Used in coordination with or duplicated by personal passwords or web accounts.
- Shared when out of the office.
- Typed in and saved in electronic documents

Minimum password length	12 characters
Maximum password age	180 days
Password history	24 (usage of last 24 passwords is not possible)

Passwords must not contain the user's account name value or entire full name value.

Complexity: Passwords must contain characters from three of the following five categories:

- Uppercase characters of European languages (A through Z, Greek and Cyrillic characters)
- Lowercase characters of European languages (a through z, sharp-s, with diacritic marks)

-
- Number (0 through 9)
 - Non-alphanumeric characters: ~ ! @ # \$ % ^ & * _ - + = ` | \ () { } [] ; : " ' < > , . ? /
 - Uppercase or lowercase.

For user support, a password safe storage solution is provided by the local IT.

3.5.2 User privileges / Information owner

The details of this chapter are described in DCT 08 - Identity and Access Management.

3.5.2.1 Information management

On internal networks, access to information is controlled selectively by user privileges (read, write, delete and create).

Any attempt to access resources on the company's IT resources, which the user either do not have access to, or should not have access to, is prohibited. Employees that have access to all information are instructed not to read or use the information that they do not need, and not to follow activities from individuals, even though it is possible. The IT responsible of each unit may though exceptionally perform such tasks (tracking) as long it serves faultfinding or fault correction.

Request of additional privileges needs to receive an approval of the responsible information owner.

Information owner is assigned to the file structure itself. For folder on department level the according MM is the responsible information owner. On group level (e.g. Supply Chain, Technology, Finance, et.) the according SM is the responsible information owner.

3.5.2.2 Least privileges

All accesses created must follow the principles of least privileges. It must be limited by the need to know and need to modify basis.

In the IT department, it applies to the administrator rights, server and network accesses.

In business units it applies to business services, data accessed and if applicable would apply as well to customer data hosted in Segula.

3.5.2.3 Segregation of duties

Segregation of duties and segregation of tasks is a principle that is enforced for all IT roles. For the business units it's the service owner or the data owner's responsibility to define accesses that would ensure that privileged accesses are properly segregated.

When it is not possible to implement a working segregation of duties, controls and checks must be implemented to ensure that the rights are not abused.

3.6 Integration of security in projects

IT projects or IT changes that have a significant impact have to follow the following rules :

- Include security objectives in the project targets
- Make a risk analysis at the start of the project or the IT change, or update the existing risk analysis when it already exist
- Include security controls and followups during the project lifecycle
- Include the security team as part of the project when required.

3.7 Network access

Network access is granted via cabling (LAN) or Wi-Fi access. Network access is authenticated via 801.2x protocol both for cabled and Wi-Fi access.

For the Wi-Fi access, DSI is running a single Wi-Fi infrastructure. It covers the sites offices. All devices with a valid access are able to use all these sites.

Any access or the attempt to access the network using a device which is not part of the by the Group – IT approved devices is automatically rejected.

3.7.1 Employee access

The network access is secured by certificate-based authentication, while certificates are installed on the employees' devices.

Access to the services and data from external is handled via secure VPN connection. VPN access is granted, if the department head determines that an employee holds a position which requires external access via VPN connection.

3.7.2 Guest access

None Segula employees can retrieve Internet access via the guest network. The guest network is available via LAN or Wi-Fi. Authentication is granted via a voucher system for each type of connection (LAN / Wi-Fi).

Using the guest network will only grant a direct internet access which is separated from DSI network in all sites.

Employees' personal devices, such as Laptops, Smartphones, Tablets, etc., are not covered under the term of "guest" and will not be automatically access.

3.8 Supplier management

In order to manage, maintain or provide IT services, Segula in some cases can call on third party suppliers. In which case:

- The suppliers are required to follow this IT security policy
- They have to be compliant with the country of work's regulations including in most cases GDPR
- If the suppliers will require privileged accounts, they will have to sign an administrator IT charter

Supplier's contract management have to include security objectives when interfacing with Segula's IT.

3.9 Antivirus

All computers, professional devices and servers shall be protected by anti-virus software or an EDR containing an AV or NGAV module. In particular the group's solution (EPP/EDR) should be the default protection software to be implemented.

Replacement can only be implemented as part of a derogation process. An update shall automatically be initiated on a regular basis, by default every 4 hours.

All e-mail communication shall be scanned for viruses, both the attachments and the message body.

3.10 External storage

Only Segula solutions are authorized on Segula workstations. Those external storage are provided to end users by the IT organization representatives and are the only one permitted on the systems.

On standard Segula workstations by default the USB storage drivers & ports are available but the EPM (Endpoint Privilege Manager) solution will enforce the USB policy.

On secured workstations, the USB storage are blocked by group policy and can only be reopened if the risk is acceptable or if other security measures can be implemented. For the most secure environments Segula IT can provide hardware-enforced encrypted external storage solutions.

Exceptions can be implemented on a case by case basis followed at the local IT management's responsibility.

3.11 E-mails

E-mails are considered to be an important part of the DSI communication system, and should only be used for company related communication. E-mails shall be written in a sober-minded way, having in mind that they origin from Segula Technologies.

The employees' E-mail accounts *may* be opened if the management decides it is in the interest of the company – taking into account eventual local restrictions (legislation). In which case the proper channel of validation will be done to ensure actions follow ethical guidelines.

Please refer to the policy for "*Internet and E-mail Services*".

3.12 Internet

The Internet is an integral part of doing business. The use of the Internet supports the company's goals and objectives. As it is a powerful tool that can bring significant benefits to the company, the DSI makes Internet access available to its employees where relevant and useful for their jobs.

3.13 Software and Hardware

Computers belonging to Segula must only be equipped with hardware and software that is approved by the IT department or IT responsible.

Use of unlicensed software is prohibited. Periodically, every site must review its software licenses to ensure that none of its employees are using unlicensed software.

A Personnel Computer user must only make minor changes in the personal software profile, for example:

- Adjustments of favorites or shortcuts
- Windows Display properties

Installation of special applications by users is only allowed with permission of the IT department or the IT responsible as long as network security and software licensing rules are not compromised.

For detailed information about the Software and Hardware please refer to “IT User Equipment”

3.14 Mobile Devices

DSI offers the use of mobile device technologies (such as smartphones and tablets) required for business purposes by DSI. This applies when a department head determines that an employee holds a position which requires that the employee be regularly available to respond to business-related communication via phone, email, text, etc. This addresses mobile devices issued by DSI only.

4 CISO organizational structure

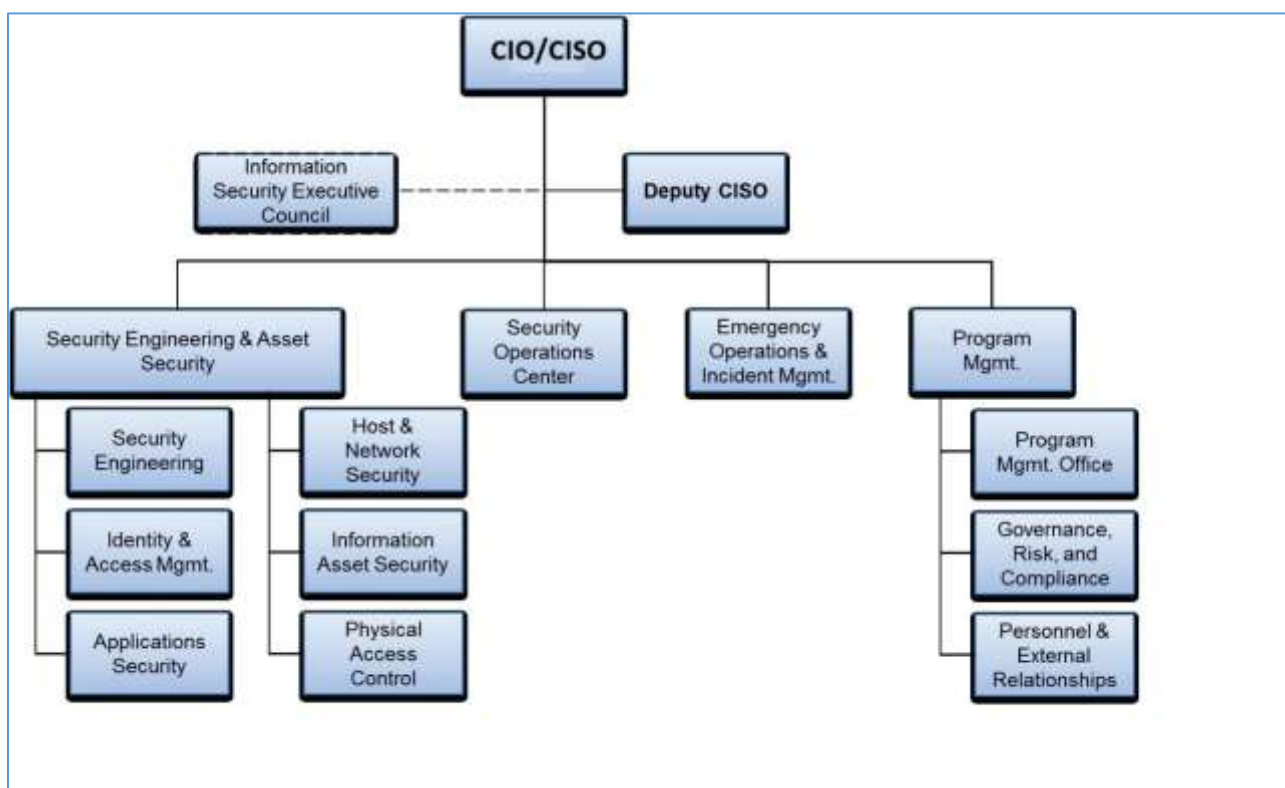


Figure 2 - CISO organisational structure

4.1 Description

4.1.1 Program Management

The Program Management unit of the CIO / CISO organization includes the three departments shown in Figure 2. The Program Management Office (PMO) performs all activities necessary to develop and successfully implement an information security plan and the program based on that plan:

- The Governance, Risk, and Compliance (GRC) unit performs all activities required to ensure proper oversight, risk management, and compliance with legal, regulatory, policy, and other information-security related requirements with which the organization is required to comply.
- The Personnel and External Relationships unit is concerned with managing relationships—those with staff and those with all external parties that are involved in the information security program

4.1.2 Security Operations Center

The Security Operations Center (SOC) is responsible for all day-to-day security operations activities, many of which may be performed by members of the IT organization with regular oversight by and reporting to members of the CISO's organization.

4.1.3 Emergency Operations and Incident Command

The Emergency Operations and Incident Command unit works closely with the SOC. The primary responsibility of this unit is to mobilize staff, activate response plans, and manage time-critical incident management and response activities when a high-impact incident is declared. During normal operations, this unit conducts the following activities in concert with members of the SOC:

- It incident management from classification to remediation
- Vulnerability auditing
- Technology watch & product evaluation
- Managing cybersecurity awareness
- Forensic and artifact handling
- Manage communication with third parties concerning incidents

4.1.4 Security Engineering and Asset Security

The Security Engineering and Asset Security unit all departments shown in Figure 2 includes two subfunctions (Security Engineering and Asset Security) in the same organizational unit is to ensure greater collaboration and cooperation between the development and acquisition activities that occur during security engineering and the operational security activities that occur to ensure that assets (hosts, networks, systems, applications, and information) are secure during operations.

5 References

IT Charter

Project	PSSI Access	PSSI Data	PSSI Operations	PSSI Business Continuity
Objective	Strengthening the Security Access Policy for the Segula infrastructure.	Strengthen the Data Exchange Security Policy	Strengthening the Security Policy for Automation of Operations	Strengthen the Security Policy of Business Continuity tools and processes
Impact	- Upgrade of AD and associated services (DNS, DHCP, AD FS, PKI, Radius) + creation of controlled a sub-domain respecting policies). - Implementation of Dual Authentication Services (MFA) and Mobile Management (MDM). - Implementation of Anti-Spam and Web Application filtering services. - Moving VPN access for all users. - Sandboxing	- Upgrade of the messaging platform: (Exchange) - Implementation of Server and Workstation File Encryption. - Implementation of a file transfer and secure printing solution - Moving data (NAS) and file shares (Sharepoint) of KLEE users.	- Implementation of an automatic update solution for servers and workstations. - Implementation of a solution for the collection and analysis of attacks on critical equipment (SIEM) that will work with our security operations center (SOC) detect, analyze, and respond to cybersecurity incidents - G1 implementation of a managed SOC 24/7 - PSSI Policies Process - EDR with regularly external controls	- Implementation of a Disaster Recovery solution (DC & Email) - Facility Management - Implementation of critical data backup of servers and workstations, (offline, inside the company and outside) - Implementation of a backup solution for critical network equipment configurations (offline, inside outside)
Products	- Active Directory 2012 - DNS, DHCP, AD FS 2016 - cisco Duo Multifactor Authentication - AirWatch Mobil Device Management - FrostPoint Antispam - Fortigate firewall (IPS activation)	- Microsoft Exchange 2019 - MBAM: Microsoft BitLocker Administration and Monitoring - Vormetric - Sharepoint - OS4X or GlobalX - Toshiba e-Bridge	- Ivanti for Servers - Mathix42 for workstations - Solarwinds (updated and safe) - SIEM	- DR DC & Email (DBD) - Facility Management (DBD) - VEEAM - BackBox - Fortimanager
Services	- DELL Technologies Professional Services - Consulting: e-Qual, NTT - System Resources + PM B-Secure	- SP DELL Technologies - Accompaniment to be provided	- Consulting M45 - Consulting e-Qual, NTT - PM B-Secure	- MTI Consulting - Accompaniment to be provided

Figure 3 - A big picture